Flyer Technical Services

CYBERSECURITY FRAMEWORK MODEL - CISA

C. H.

Flyer Tech – Security Analyst

Table of Contents

Part 1 – US Compliance and Laws Research 3

Overview and Purpose 3

US Compliance Laws 3

US Regulations and Laws 4

Part 2 – Infrastructure Research A 5

Cybersecurity Framework Model Overview 5

Cyber Policy Development for Flyer Tech 6

Policy 1 – Acceptable Encryption 6

Policy 2 – Acceptable Use Policy 6

Policy 3 – Artificial Intelligence Use Policy 7

Policy 4 – Bluetooth Baseline Requirements Policy 8

Policy 5 – Cyber Security Incident Documentation & Handling 9

Policy 7 – Email Policy 10

Policy 8 – Information Logging Policy 11

Policy 9 – Password Construction Guidelines 12

Policy 10 – Password Protection Policy 13

Policy 11 – Remote Access Policy 14

Policy 12 – Server Security Policy 16

Policy 13 – Software Installation Policy 17

Policy 14 – Technology Equipment Disposal Policy 18

Policy 15 – Wireless Communication Policy 20

Standards Development for Flyer Tech 22

Standard 1 – Data Protection Standard 22

Standard 2 – Acceptable Use Standard 22

Standard 3 – Bluetooth Baseline Requirement Standard 23

Standard 4 – Cyber Security Incident Documentation & Handling Standard 23

Standard 5 – Email Communication & Usage Standard 24

Standard 6 – Information Logging Standard 24

Standard 7 – Password Construction Standard 24

Standard 8 – Remote Access Standard 25

Standard 9 – Server Security Standard 25

Standard 10 – Wireless communication standard 26

Part 3 – Infrastructure Research B 26

User Domain 26

Controls for User Domain 27

Workstation Domain 29

Controls for Workstation Domain 30

LAN Domain 31

Controls for LAN Domain 32

LAN to WAN Domain 34

Controls for LAN to WAN Domain 34

WAN Domain 35

Controls for WAN Domain 36

Remote Access Domain 37

Controls for Remote Access Domain 38

Systems/Applications Domain 39

Controls for Systems/Applications Domain 41

Part 4 – Conclusions and Outcomes of Overall Report 43

References 44

Part 1 – US Compliance and Laws Research

Overview and Purpose

At Flyer Technical Services (Flyer Tech) we are a private company operating out of Romeoville Illinois. We partner with Industry leaders to provide data storage, networking, virtualization, and cybersecurity services for our clients. Security and protection of our clients is very important to us, we are committed and will prioritize staying in accordance with the Cybersecurity & Infrastructure Agency (CISA) compliances. With constant threats to information security evolving, so must we in the consistent updating and practices that seek to improve in any way possible to counteract these threats.

Flyer Tech has been awarded a contract under CISA and as a company will be ready to uphold the contractual obligations and complete them security and effectively. Our mission is to adhere to and fulfill all requirements required under CISA. This remainder document will outline the standards, regulations, and controls that are to be expected and implemented by Flyer Tech personnel, resources will be available to serve as guidelines for future compliances.

US Compliance Laws

Some United States' compliance laws we should direct our attention to include the Payment Card Industry Data Security Standard (PCI DSS) which ensures the safe and secure transfer of credit card data, the Federal Trade Commission Act (15 USC

section 41 et seq) which gives the FTC broad authority to protect consumers against an organization's failure to follow basic cybersecurity and privacy practices, NIST SP 800-53 Rev. 5 (Security and Privacy Controls for Federal Information Systems and Organizations) provides a series of controls for implementation in accordance with the Office of Management and Budget (OMB), the Center for Internet Security (CIS) Controls which is a set of best practices to enhance the cybersecurity posture of an organization, as well as NIST Cybersecurity Framework (NIST CSF) in order to improve the risk management amongst this organization.

US Regulations and Laws

Under United States law we must adhere to the Federal Information Security Management Act (FISMA). FISMA is intended to create "mandatory requirements in order to ensure the integrity, confidentiality, and availability of data"(Easttom & Johnson, 2022, p.203) so long as this organization processes government data. In addition to FISMA, the Cybersecurity Information Sharing Act (CISA) and Federal Risk & Authorization Management Program (FedRamp) in order to encourage sharing of information between private organizations and the government, enhancing cybersecurity threat intelligence as well as requiring cloud service providers meet NIST-based security standards.

Part 2 – Infrastructure Research A

Cybersecurity Framework Model Overview

Flyer Tech has outlined this compliance framework with the purpose of protecting the information of personnel and most importantly the data of our clientele. Remaining compliant with United States federal regulations and laws including the Federal Information Security Management Act (FISMA) which ensures that the data within our systems may be kept confidential, available, and our systems integrity remains at its highest point. The framework outlined here is in compliance with the Cybersecurity Information Sharing Act (CISA) meaning we will be in constant communication with the government and other private companies to pool our knowledge and enhance our knowledge of known and soon to be known intelligence threats to our cybersecurity.

The policies outlined in this framework hold the purpose of reducing risks to the cybersecurity and intelligence of Flyer Tech in its entirety. In order to limit these risks, we must identify and improve potential weak areas prioritizing core security practices for personnel within their respective work environments utilizing the full potential of the allotted budget.

The hopes of this framework is to uplift and build confidence within the personnel of Flyer Tech to better protect this organization, the benefit being that we are able to build off of their personal safety habits and safety knowledge they may already have. The security habits that will be expected of staff will not be difficult to process. By providing easily digestible information about security and keeping metrics of where they

fail to meet the proper security posture expected of them personally, strengthening good security habits and boosting the cybersecurity posture of Flyer Tech.

Since this organization has not had a contract like this before, we will need to build new controls into our policies. Luckily establishing new controls in compliance with CISA will not be difficult due to the intersectionality that comes with the territory that is cybersecurity. With the pool of knowledge for security risks, we will remain atop of potential risks as well as providing knowledge of our own findings as outlined by CISA.

Cyber Policy Development for Flyer Tech

Policy 1 – Acceptable Encryption

This policy applies to all Flyer Tech employees and affiliates. This policy serves the purpose of providing guidance, limiting use of encryption algorithms to those that have received substantial public review and have been proven to work effectively. Flyer Tech requires use of encryption for client data and information about security risks shared amongst government agencies and various other private organizations.

Flyer Tech will adhere to NIST Policy on Hash Functions and the Cryptographic Module Validation Program (CMVP) also provided by NIST. The Infosec team at Flyer Tech will verify compliance with this policy through various methods, including internal and external audits, feedback to the policy owner, and business tool reports. No exceptions are to be made over data pertaining to our clientele and communications with other cleared government and company entities. In the event of failure or breach of policy is uncovered, the offending employee may be subject to disciplinary actions including the termination of employment.

Policy 2 – Acceptable Use Policy

Flyer Tech proprietary information stored on electronic computing devices whether owned or leased by Flyer Tech, the employee, or a third party, remains the sole property of Flyer Technical Services. Through legal or technical means, you must ensure proprietary information is being protected in accordance with the Data Protection Standard. It is your responsibility to report any theft, loss, damage, or unauthorized disclosure of Flyer Tech proprietary information.

Company devices may be used to access, use, or share Flyer Tech proprietary information within the extent authorized and required in order to complete assigned tasks and job duties. Employees are responsible for utilizing good judgement in regards to the reasonableness of personal use. While there will be a uniform policy covering Internet/Intranet/Extranet usage, individual departments will be required to establish guidelines in accordance with their respective department responsibilities; should there be any uncertainty surrounding what is required, employees should consult with their supervisors or managers.

For security and network maintenance tasks, authorized personnel within Flyer Tech may monitor equipment, systems, and network traffic at any time, per InfoSec's Audit Policy. Flyer Tech reserves the right to audit networks and systems on a periodic basis to ensure compliance with this policy.

Policy 3 – Artificial Intelligence Use Policy

Flyer Tech is committed to full compliance with applicable laws related to artificial intelligence usage within the United States. In addition, Flyer Tech is committed to the ethical usage of artificial intelligence. This Artificial Intelligence Use Policy (AIUP)

outlines Flyer Tech requirements with respect for the adoption of all forms of artificial intelligence within select departments of Flyer Tech. Artificial intelligence adoption includes use for sorting, automation, and inclusion within select programs at Flyer Tech.

This policy applies to all personnel at Flyer Tech including directors, officers, board members, employees, contractors, representatives, affiliates, agents, and any person or entity performing services for or on behalf of Flyer Tech. In conjunction with network monitoring by InfoSec, the Responsible Corporate Officer at Flyer Tech will be responsible for the enforcement of this policy.

Policy 4 – Bluetooth Baseline Requirements Policy

Insecure Bluetooth connections can add risk to the security of devices and information hosted by Flyer Tech. To minimize security issues from insecure connections, baseline requirements are needed. Connecting Bluetooth devices to the Flyer Tech network or Flyer Tech owned devices requires the use of a minimum standard to ensure sufficient protection for Personally Identifiable Information (PII) as well as confidential Flyer Tech data.

This policy is applicable to any Bluetooth enabled device that is connected to Flyer Tech network or owned devices. No Bluetooth devices are to be deployed on Flyer Tech equipment without meeting the minimum of Bluetooth v2.1 specifications; exceptions can only be made with written authorization provided by the InfoSec Team stating otherwise. Any and all Bluetooth equipment purchased or acquired prior to the implementation of this policy must comply with all parts of this policy except the Bluetooth version specifications.

When pairing a Bluetooth device, avoid entering pins over public unprotected networks and entering your pin after initial pairing. The following security specifications must be met for Bluetooth devices, they must employ ‘security mode 3’ providing end-to-end encryption, PINs

must meet a minimum length of 8 characters, switch Bluetooth devices into non-discoverable or hidden mode, only activate Bluetooth when it is needed, ensure device firmware is up-to-date. The InfoSec Team may perform random audits to ensure compliance with the policy, they may not eavesdrop on any phone conversations during the performance of these audits.

Policy 5 – Cyber Security Incident Documentation & Handling

In the event of an incident involving the breach of Flyer Tech cybersecurity, the InfoSec Team will be responsible for the documentation, isolation, and securing of Flyer Tech network and devices posing a risk to the security architecture. The following forms the InfoSec teams will need to properly fill and report include, incident communications logs & chain of custody, incident containment & recovery, incident response summary & triage. Security Details are to be properly handled as stated prior and communicated with government and other private organizations in compliance with CISA.

Policy 6 – Database Credentials Policy

Database authentication credentials are a necessary part for interfacing/connecting with the database. Improper, storage, and sharing of such credentials could bring about compromises of sensitive assets as well as an opportunity for a greater compromise within the Flyer Tech. This policy dictates the proper storing and retrieval of database usernames and passwords for use by a program that will access a database running on the Flyer Tech network.

Database credentials may be stored in a file separate from the executing body of the program's code. The file storing credentials must not be stored in plain text, instead opt for encryption that follows the NIST publication FIPS 140-2. The use of RSA and Elliptic Curve Cryptography (ECC) algorithms are strongly recommended for

asymmetric encryption. Credentials may reside on the database server, in this case only hash function numbers identifying the credentials may be stored on the executing body of the program's code. Passwords within the credentials must adhere to the Password Policy and may not reside in the document tree of a web server, credentials may be stored within authentication servers for the purpose of user authentication.

Policy 7 – Email Policy

With email being the primary way communications take place within Flyer Tech, the misuse of this system must be taken seriously to ensure any legal, privacy, or security risks never take place. Personnel of Flyer Tech must be aware of what is deemed acceptable and unacceptable use of its email system, this policy outlines those requirements for compliance. This policy applies to all employees, vendors, and agents operating on behalf of Flyer Tech and its assets.

All use of email must be consistent with Flyer Tech policies and procedures of ethical conduct, safety, compliance with applicable laws and proper business practices. Flyer Tech email accounts should be used solely for Flyer Tech business related purposes; personal communications are allowed within limited parameters, but non Flyer Tech commercial usage is strictly prohibited. All data contained within email messages or attachments must be secured in accordance with the Data Protection Standard.

Emails should be retained as business record so long as it exists within legitimate and ongoing business reason for the preservation of the contained information; the information should also follow Flyer Tech Record Retention Schedule. The Flyer Tech email systems shall not be used for the creation or distribution of any

disruptive or offensive messages, including offensive comments about race, gender, hair color, age, disabilities, sexual orientation, pornography, religious beliefs and practices, political beliefs, or national origin. Employees who receive any emails involving these contents should report the matter to their supervisor immediately. Automatic forwarding of Flyer Tech emails to a third party email system or server storage such as Google, Yahoo, MSN Hotmail etc. to conduct Flyer Tech business to create or memorialize any binding transactions, or to store or retain email on behalf of Flyer Tech. Individual messages forwarded by the user must not contain Flyer Tech confidential or above information.

Policy 8 – Information Logging Policy

Logging from critical systems, applications and services could provide key information and potential indicators of compromise. It is critical to have logging information available for forensic purposes, though it may not be viewed on a daily basis. This policy addresses logging issues by identifying specifications and requirements Flyer Tech information systems must meet in order to generate proper audit logs and integrate with enterprise log management functions.

This policy is applicable to production systems on the Flyer Tech network and the language of this policy may be adapted for enterprise IT security policy and standards. All systems that handle confidential information, accept network connections, or make access control (authentication and authorization) decisions shall record and retain audit logging information sufficient to answer the following questions:

- What activity was performed?

- Who or what performed the activity, including where or on what system the activity was performed from (subject)?
- What the activity was performed on (object)?
- When was the activity performed?
- What tool(s) was the activity performed with?
- What was the status (such as success vs. failure), outcome, or result of the activity?

Logs shall be created whenever changes are made to confidential information, network, or access information. The InfoSec Team will verify compliance to this policy through various methods including business tool reports, internal and external audits, and feedback from the policy owner. Any exemptions to this policy must be approved by the InfoSec Team in advance, any lack of compliance by any employee will be met with disciplinary action, up to and including the termination of employment.

Policy 9 – Password Construction Guidelines

Passwords are of the most essential components for security, the integrity of a password directly correlates to safety and security of the Flyer Tech network. Passwords created must meet the outlined requirements of this policy. This policy guideline applies to employees, contractors, consultants, temporary and other workers, including all personnel affiliated with third parties. This policy is also applicable to all passwords including but not limited to user-level accounts, system-level accounts, web accounts, email accounts, screen saver protection, voicemail, and local router logins.

It is recommended that passwords meet a minimum of 16 characters in length due to longer passwords having stronger security, it is also recommended that

passphrases are used. Passphrases are passwords made up of multiple words. Examples of passphrases include: “Science-Fiction-Is-Awesome” or “Blue Notebook White Desk”. Passphrases are easier to remember and type while meeting the password length requirement.

Password cracking or guessing may be performed periodically by the InfoSec team or its delegates; in the instance a password is guessed or cracked during these scans, the user will be required to change it. Any exceptions to this policy will need to be cleared by the InfoSec team. An employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

Policy 10 – Password Protection Policy

Coinciding with the creation of passwords, a weak or compromised password can result in unauthorized access to the sensitive data and exploitation of Flyer Tech resources. All staff, including contractors and vendors with access to Flyer Tech systems, are responsible for taking the appropriate steps to secure their password as outlined below. A secure standard for the protection of all work related passwords.

All user-level and system-level passwords must be in compliance with the Password Construction Guidelines. Users must use separate unique passwords for each of their work related accounts and must refrain from using work related passwords for personal accounts. Staff are permitted to use authorized, approved password managers to securely store and manage all their work passwords.

Any user accounts that possess system level privileges granted through group memberships or programs such as sudo must use a unique password from their other accounts held by that user to access system-level privileges; using some form of multi

factor authentication (MFA) or (2FA) is recommended for any privileged accounts. Only change a password if it is compromised or fails to meet the creation guidelines. The use or setting of regular password expiration is not recommended.

Passwords must not be shared with anyone; this includes supervisors and coworkers. All passwords must be treated as sensitive or confidential Flyer Tech information, passwords are not to be entered in email or any other form of electronic communication, nor should they be shared over the phone to anyone. Never enable the “remember password” feature.

Policy 11 – Remote Access Policy

Remote access can be an essential part of team productivity, but in many cases remote access connections could originate from a server that is already compromised or possessing a significantly lower security posture than our corporate headquarters. While remote networks are beyond the controls of Flyer Tech policy, we must mitigate these external risks to the best of our ability. The purpose is to define and refine the rules and requirements for connecting to Flyer Tech’s network from any host.

This policy applies to all Flyer Tech employees, contractors, vendors and agents with a Flyer Tech-owned or personally owned computer or workstation used to connect to the Flyer Tech network. This applies to all remote access connections used to do work on behalf of Flyer Tech, including reading or sending email and viewing intranet web resources. It is the responsibility of Flyer Tech employees, contractors, vendors and agents(hereafter referred to as “Authorized Users”) with remote access privilege to Flyer Tech’s corporate network to ensure that their remote access connections are given the same consideration as the user’s on site connection to Flyer Tech. General

access to the internet for recreational use through the Flyer Tech network is strictly limited to Flyer Tech's Authorized Users.

Requirements for remote access connections goes as follows

- Secure remote access must be strictly controlled with encryption (i.e., Virtual Private Networks (VPNS)) and strong passphrases. For further information see the Acceptable Encryption Policy and the Password Policy
- Authorized Users shall protect their login and password, even from family members.
- While using a Flyer Tech-owned computer to remotely connect to Flyer Tech's corporate network, Authorized Users shall ensure the remote host is not connected to any other network at the same time with the exception of personal networks that are under their complete control or control of an Authorized user or Third Party.
- The use of external resources to conduct Flyer Tech business must be approved in advance by the InfoSec Team and the appropriate business unit manager.
- All hosts connected to the Flyer Tech internal networks via remote access must use the most up-to-date anti-virus software, this includes personal computers. Third party connections must comply with requirements.
- Personal equipment used to connect to Flyer Tech's network must meet requirements of Flyer Tech-owned equipment for remote access.

The InfoSec team will verify policy compliance through various methods, including but not limited to, business tool reports, internal and external audits, and feedback to the policy owner. Any exceptions to this policy must be cleared by the InfoSec team in

advance, an employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

Policy 12 – Server Security Policy

Vulnerable/Unsecured servers continue to be a major entry point for malicious threat actors. The purpose of this policy is to establish standards for the base configuration of internal server equipment that is owned and/or operated by Flyer Tech. Effective implementation of this policy will minimize unauthorized access to Flyer Tech proprietary information and technology.

All employees, contractors, consultants, temporary and other workers at Flyer Tech and its subsidiaries must adhere to this policy. This policy is applicable to server equipment that is owned, operated, or leased by Flyer Tech or registered under a Flyer Tech-owned internal network domain. This policy specifies requirements for equipment on the internal Flyer Tech network.

Requirements for this policy goes as follows:

- All internal servers deployed at Flyer Tech must be owned by an operational group that is responsible for system administration. Approved server configuration guides must be established and maintained by each operational group, based on business news, and approved by the InfoSec team.
- Operational groups should monitor configuration compliance and implement an exception policy tailored to their environment. Each operational group must establish a process for changing the configuration guides, which includes review and approval by InfoSec.

Any exceptions to this policy must be cleared by the InfoSec team in advance, an employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

Policy 13 – Software Installation Policy

Allowing employees to install software on company computing devices opens the organization up to unnecessary exposure. Unlicensed, incompatible, or malicious software could be problems faced when employees install software on company equipment. The purpose of this policy is to outline the requirements around the installation of software on Flyer Tech computing devices, minimizing the risk associated with the exposure.

This policy applies to all Flyer Tech employees, contractors, vendors, and agents with Flyer Tech-owned mobile devices. This policy is applicable to all computers, servers, smartphones, tablets and other computing devices operating within Flyer Tech.

- Employees may not install software on Flyer Tech computing devices operated within the Flyer Tech network
- Software requests must first be approved by the requester's manager and then be made to the information technology department or Help Desk in writing or via email.
- Software must be selected from an approved software list, maintained by the Information Technology department, unless no selection on the list meets the requester's need.
- The Information Technology Department will obtain and track the licenses, test new software for conflict and compatibility, and perform the installation.

The InfoSec team will verify policy compliance through various methods, including but not limited to, business tool reports, internal and external audits, and feedback to the policy owner. Any exceptions to this policy must be cleared by the InfoSec team in advance, an employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

Policy 14 – Technology Equipment Disposal Policy

Technology equipment often contains parts that cannot simply be thrown away. Proper disposal of equipment is both environmentally responsible and often required by law. In addition, USB drives, hard drives, and other kinds of storage media may contain Flyer Tech data that may be considered sensitive. In order to protect our constituent's data, all storage mediums must be properly erased before being disposed of. Deleting files and formatting data is not sufficient for the disposal of information as this data is still available until overwritten by a new file. Special tools must be used to securely erase data prior to equipment disposal.

The purpose of this policy is to provide guidelines for the disposal of technology equipment and components owned by Flyer Tech as well as parameters for what is deemed sufficient. This policy applies to any computer/technology equipment or peripheral devices that are no longer needed within Flyer Tech including but not limited to personal computers, servers, hard drives, laptops, mainframes, smart phones, or handheld computers (i.e., Windows Mobile, iOS or Android-based devices), peripherals (i.e., keyboards, mice, speakers), printers, scanners, typewriters, compact and floppy discs, portable storage devices (i.e., USB drives), backup tapes, printed materials. All

Flyer Tech personnel and affiliates must comply with this policy. Requirements go as follows:

- Tech at the end of its useful life should be sent to our equipment disposal team for proper disposal.
- The equipment disposal team will securely erase all storage mediums in accordance with current industry best practices.
- All data including, all files and licensed software shall be removed from equipment using disk sanitizing software that cleans the media overwriting each and every disk sector of the machine with zero-filled blocks.
- No computer or technology equipment may be sold to any individual other than through the processes identified in this policy.
- No computer equipment should be disposed of via skips, dumps, landfill etc. Electronic recycling bins may be periodically placed in locations around Flyer Tech. These can be used to dispose of equipment.
- All electronic drives must be degaussed or overwritten with a commercially available disk cleaning program. Hard drives may also be removed and rendered unreadable (drilling, crushing or other demolition methods).
- Computer Equipment refers to desktop, laptop, tablet or netbook computers, printers, copiers, monitors, servers, handheld devices, telephones, cell phones, disc drives or any storage device, network switches, routers, wireless access points, batteries, backup tapes, etc.

- The equipment disposal team will place a sticker on the equipment case indicating the disk wipe has been performed. The sticker will include the date and the initials of the technician who performed the disk wipe.
- Technology equipment with non-functioning memory or storage technology will have the memory or storage device removed and it will be physically destroyed.

The InfoSec team will verify policy compliance through various methods, including but not limited to, business tool reports, internal and external audits, and feedback to the policy owner. Any exceptions to this policy must be cleared by the InfoSec team in advance, an employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

Policy 15 – Wireless Communication Policy

Insecure wireless configuration can provide easy access for malicious threat actors to attack the Flyer Tech network. The purpose of this policy is to secure and protect the information assets owned by Flyer Tech. Flyer Tech provides computers, networks, and other electronic information systems to meet missions, goals, and initiatives. Flyer Tech grants access to these resources as a privilege and must manage them responsibility to maintain the confidentiality, integrity, and availability of all information assets.

This policy specifies the conditions that wireless infrastructure devices must satisfy in order to make connections with the Flyer Tech network. Only wireless devices that meet the specified standards in this policy or devices that are granted an exception by the InfoSec Department for connectivity to a Flyer Tech network.

All employees, contractors, consultants, temporary and other workers at Flyer Tech, including all personnel affiliated with third parties that maintain a wireless infrastructure device on behalf of Flyer Tech must adhere to this policy. This policy applies to all wireless infrastructure devices that connect to a Flyer Tech network or reside on a Flyer Tech site that provide wireless connectivity to endpoint devices including, but not limited to, laptops, desktops, cellular phones, and tablets. This includes any form of wireless communication device capable of transmitting packet data.

All wireless infrastructure devices within the Flyer Tech site, connecting to a Flyer Tech network or providing access to information classified as Flyer Tech Confidential, or above must adhere to the following requirements:

- Abide by the standards specified in the Wireless Communication Standard.
- Be installed, supported, and maintained by an approved support team.
- Use Flyer Tech approved authentication protocols and infrastructure.
- User Flyer Tech approved encryption protocols.
- Maintain a hardware address (MAC address) that can be registered and tracked.
- Does not interfere with wireless access deployments maintained by other support organizations.

The InfoSec team will verify policy compliance through various methods, including but not limited to, business tool reports, internal and external audits, and feedback to the policy owner. Any exceptions to this policy must be cleared by the InfoSec team in advance, an employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

Standards Development for Flyer Tech

Standard 1 – Data Protection Standard

Managing security and privacy risks is a complex, multifaceted undertaking that requires well-defined security and privacy requirements, trustworthy information system components, rigorous security and privacy planning and system development, application of system security and privacy practices with proper documentation, and continuous monitoring of information systems.

To address Flyer Tech security concerns about assessment and determination of risk, security and privacy requirements are satisfied with the knowledge and understanding of our risk management strategy. The catalog of security and privacy controls can be effectively used to protect organizations, individuals, and information systems from traditional and advanced persistent threats and privacy risks arising from the processing of personally identifiable information (PII) in varied operational, environmental, and technical scenarios.

Standard 2 – Acceptable Use Standard

Maintaining the integrity of how people utilize Flyer Tech resources is vital to operations, though this is a very simple thing to state and hope employees will refer back to, there needs to be a broad scope of coverage making implementation difficult especially given the specificity needed to corral the attention to strictly production and meaningful usage of company software and hardware. In order to combat wandering means leading to wandering eyes, this standard will safe-guard what is strictly allowed, strictly prohibited, and exceptions with appropriate protocols to follow should an

individual decide to access something outside of company priorities or in direct inverse of said priorities.

Standard 3 – Bluetooth Baseline Requirement Standard

Bluetooth usage as far as company standards is essential, but personal use of bluetooth is a privilege that should not be taken for granted including its fair share of work to maintain allowing continued usage. All company hardware and software involved in bluetooth connections will carry its section of maintenance for company security checks, but personal equipment will fall on the user to keep up-to-date and functional otherwise risk a breach in security; explicit usage of personal bluetooth equipment to interact with Flyer Tech-owned devices is strictly prohibited under this policy to reduce the amount of resources allocated to security.

Standard 4 – Cyber Security Incident Documentation & Handling Standard

The logging and documentation of Flyer Tech incidences and operations is imperative to keeping track of what happened, where it happened, and who had access at the time in order to better plan a course of action in the case of an incident or control and correct an issue in the case of something like misplaced files, a breach, or even negligence on a given individuals part. Nothing is to be overlooked for the use of these procedures, all IT personnel are required to keep at least some basic documentation when handling issues or something of priority that could open up Flyer Tech to a potential issue. The correct forms will be accessible in the case of regular security checks and reports, automated system logs will also need regular monitoring during scheduled auditing.

Standard 5 – Email Communication & Usage Standard

The usage of email communication systems are integral to the operations of Flyer Tech, at no time should there be personal use of Flyer Tech email communication systems, the is for the importance of data leak risks or an employee's personal business being directly linked to company operations which would not only violate this standard and policy, but the company-wide acceptable use policy and standard. Company hardware and email systems will have built in filtering that will parse through emails flagging any sensitive information allowing the InfoSec team to review and consult with the individual sending the email to prevent and correct any future misuse of company resources, such information can include company secrets, company operations, sending emails to anyone outside the Flyer Tech network, as well as links both inbound and outbound to prevent the spreading of viruses or attacks.

Standard 6 – Information Logging Standard

This standard helps to keep tabs on the current operations of Flyer Tech at any given moment, the information logged being used to perform regular security audits and a healthy knowledge of company workflow. Important information to note when logging would be who currently possesses a device and which device exactly as well as the purpose of them having it. In the case of misuse or tampering through any given device, it will be easier for the InfoSec team to track down and nullify the security risk.

Standard 7 – Password Construction Standard

Passwords are a great safeguard to any operation and provide an important wall of security for any would-be risk, it is important that passwords possess specific characteristics that provide security to Flyer Tech operations as well its personnel.

Easily forgotten/complex passwords would not be optimal given the resources used to reset it, but it would be more secure than an easily remembered/simple password. For a healthy medium, passphrases would be optimal given that they are both easily remembered and complex. The application of this standard would be to ensure nobody is an easy target, as well as providing a security practice people can take home with them to better secure themselves and by proxy, company assets.

Standard 8 – Remote Access Standard

Remote access is an important part of Flyer Tech function, not only for our clients utilizing virtualization functions, but also for employees that may be away from the office in the case they have to fix something or work from home. Guidelines surrounding appropriate use of this specific function provides a clear expectation of what is expected out the employee as well as appropriate device standards that are required prior to the access of company resources, this would be an important time for company hardware to be lent out.

Controls on client access will be important but to a lesser degree given their usage will be implemented on a mostly separate network with little communication to main company servers outside of monitoring, bug fixing, and isolation of hardware should there be a threat actor or malicious software taking foothold in company resources.

Standard 9 – Server Security Standard

Company servers must meet the minimum security requirements outlined by Flyer Tech. This standard comes with importance governing operation security,

personnel security, and most importantly client security. Oversight of server security is not an option meaning this will be of the highest priorities for our team.

Standard 10 – Wireless communication standard

Today, wireless emergency response communications systems suffer from similar incompatibility problems. With these radio systems, however, convenience is not the issue. Wireless emergency response communications exist to help save lives and protect property. Law enforcement personnel, firefighters, EMS professionals, and other emergency responders need to be able to communicate with each other to effectively coordinate their efforts. Open standards must be adopted and put into place. When equipment is built to open standards, components can operate with each other, regardless of manufacturer. Emergency response personnel can then share information, coordinate efforts, and maximize success in saving lives and safeguarding property.

Part 3 – Infrastructure Research B

User Domain

Refers to any end user accessing information in any form, generally including how physical information is handled by employees. Starts with end user awareness of policies and on-the-job training.

Applicable Policies & Standards

Policy 2 – Acceptable Use Policy – This policy defines the rules for user behavior and ensures that users understand what is allowed and what is not;

Policy 3 – Artificial Intelligence Use Policy – This policy governs the use of artificial intelligence in the organization, including rules for AI development and deployment;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents involving users;

Policy 7 – Email Policy – This policy governs the use of email by users, including rules for sending and receiving emails;

Policy 9 – Password Construction Guidelines – This policy sets the rules for creating strong passwords for users;

Policy 10 – Password Protection Policy – This policy governs the protection of passwords used by users;

Standard 1 – Data Protection Standard – Users are expected to protect sensitive data and maintain confidentiality. This includes using strong passwords, locking workstations, and reporting any potential security incidents;

Standard 2 – Acceptable Use Standard – Users must adhere to the organization's acceptable use policy, which outlines prohibited activities such as accessing unauthorized websites or using company resources for personal gain;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – Users are required to report any security incidents, such as suspicious emails or unauthorized access, to the incident response team;

Standard 7 – Password Construction Standard – Users must create strong, unique passwords that meet the organization's password complexity requirements.

Controls for User Domain

- AC-2 – Account Management – Ensures proper provisioning, management, and deactivation of user accounts. Helps prevent unauthorized access and enforces lifecycle security. This control will greatly reduce the chances of a security risk from a dormant account. AC-2 was selected due to its practicality, the importance of this element of security cannot be overlooked.
- IA-2 – Identification and Authentication – Enforces strong user verification processes. Verifies user identities before granting access, preventing impersonation. Proper avenues of authentication are crucial, especially in the user domain where security awareness is baked into the experience.
- IA-5 – Authenticator Management – Governs creation, distribution, and revocation of credentials. Strengthens the integrity and protection of passwords and tokens. Controlling how, who, and when credentials are made, given, and taken away build makes tracing a paper trail much easier. If a set of credentials slide through the cracks and a threat actor finds them, the documentation and

protocols surrounding credentials will make it very simple to track down–breaches can be pinpointed.

- AT-2 – Literacy Training and Awareness – Provides training on safe usage, phishing, AI misuse, etc. Reduces human error and increases user vigilance. If employees at Flyer Tech know what to look for when determining the validity and safety of an email can limit the chances of someone falling for phishing schemes. A clear understanding of what attackers may do to latch onto someone is great for all levels of this company to keep in mind, especially at the user domain level.
- AC-8 – System Use Notification – Displays login banners with rules and monitoring notices. Legally informs users and deters inappropriate system use. Adding an element to introduce a sense of surveillance for people can greatly reduce the chances of company hardware being misused. At the user level it could become very easy for people to assume they can interact with their provided devices in whatever manner they decide.
- PS-3 – Personnel Screening – Ensures background checks for users with access to sensitive systems. Reduces risk of insider threats or negligent hires. If a new hire or user starts by not adhering to rules or hasn't in their past, they do not need our attention–the more resources we can appropriately divulge to worthy applicants will prove to be more beneficial.
- AC-6 – Least Privilege – Restricts users to only the access they need. Minimizes damage from account compromise or misuse. Personnel at Flyer Tech with less responsibility requirements do not require higher clearance–human resources do not need the ability to access the same information as our information security

team. Alternatively, someone in security does not need access to company financial records.

- IR-6 – Incident Reporting – Requires users to report suspicious or malicious activity. Enables faster response to threats and educates users to be part of the detection process. Proper avenues to report and document security incidents is important for our security professionals to appropriately respond and secure us.
- SC-12 – Cryptographic Key Establishment and Management – Applies encryption to protect user credentials and communications. Secures sensitive data, especially in login sessions and email–proprietary company data should not be easily accessible from outside the Flyer Tech network. Encrypted information at a user level through proper credentials or virtual private networks is for personnel and company protection.
- PL-4 – Rules of Behavior – Establishes a formal acknowledgment of system usage expectations. Promotes accountability and compliance through user sign-offs–tracking who and when someone has something makes tracking problems significantly easier. The better the paper trail, the better our security team can respond if any incident reveals itself.

Workstation Domain

Includes any computing devices used by end users. The term workstation usually refers to a desktop or laptop computer; however, for clarity in this document will be any end user device that accesses information.

Applicable Policies & Standards

Policy 1 – Acceptable Encryption – This policy is relevant to the workstation domain because it ensures that data stored on workstations is encrypted to protect against unauthorized access;

Policy 2 – Acceptable Use Policy – This policy defines the rules for using workstations and ensures that users understand what is allowed and what is not;

Policy 4 – Bluetooth Baseline Requirements Policy – This policy sets the requirements for Bluetooth devices connected to workstations, ensuring that they meet minimum security standards;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents on workstations;

Policy 7 – Email Policy – This policy governs the use of email on workstations, including rules for sending and receiving emails;

Policy 8 – Information Logging Policy – This policy defines how information is logged on workstations, including system events and user activities;

Policy 9 – Password Construction Guidelines – This policy sets the rules for creating strong passwords on workstations;

Policy 13 – Software Installation Policy – This policy governs the installation of software on workstations, ensuring that only approved software is installed;

Policy 14 – Technology Equipment Disposal Policy – This policy outlines the procedures for disposing of workstations and other technology equipment in a secure manner;

Standard 1 – Data Protection Standard – Workstations must be configured to protect sensitive data, including encrypting data at rest and in transit;

Standard 2 – Acceptable Use Standard – Workstations are subject to the organization's acceptable use policy, which outlines prohibited activities;

Standard 3 – Bluetooth Baseline Requirement Standard – Workstations with Bluetooth capabilities must be configured to meet the organization's Bluetooth security requirements;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – Workstation users must report any security incidents to the incident response team;

Standard 5 – Email Communication & Usage Standard – Workstations are subject to the organization's email communication and usage policy, which outlines proper email etiquette and usage guidelines;

Standard 6 – Information Logging Standard – Workstations must be configured to log security-related events, such as login attempts and access to sensitive data.

Controls for Workstation Domain

- CM-6 – Configuration Settings – Enforces secure settings in application environments. Prevents misconfiguration-related vulnerabilities–if company applications are improperly configured, our systems could become more breach prone. Properly ensuring security settings are appropriately set protect Flyer Tech hardware and networks.
- SI-3 – Malicious Code Protection – Detects and prevents malware infections through scanning. Protects endpoints from viruses, spyware, and other malicious software. In the case someone has a malware infection on their hardware, routine scans will be required to ensure the safety of said personnel’s information as well as company proprietary information.

- SC-7 – Boundary Protection – Controls traffic flow at network boundaries. Prevents unauthorized data flow and access into and out of workstations. Accessing non-Flyer Tech related information outside of what is deemed acceptable will be monitored and blocked for the safeguarding and limiting of security breaches–under no time will anything outside of Flyer Tech operations be appropriate on company-owned hardware.
- SI-2 – Flaw Remediation – Ensures timely patching of vulnerabilities. Reduces exposure to known exploits and enhances system resilience. Any discovered system exploits will have patches put in place–through routine penetration testing, security vulnerability scans, and incident reporting, our security measures will become more hardened, this also comes with attention placed on the ever maturing nature of our security posture.
- AC-11 – Device Lock – Automatically locks devices after inactivity. Prevents unauthorized access when workstations are unattended. It becomes easy to get up and leave a device unattended–to prevent others from accessing proprietary data, it is required that timeout features be put in place. Though automated features will be put in place on company hardware, we recommend that all Flyer Tech personnel develop the habit of turning off devices if they plan to be gone for more than twenty minutes.
- MP-6 – Media Sanitization – Ensures secure erasure of data on media before reuse or disposal. Prevents data leakage from decommissioned or repurposed devices–hardware that is to be discontinued must have their hard drives

destroyed to prevent leaking of confidential data. In the case of hardware reuse, devices shall remain within the same department.

- SC-28 – Protection of Information at Rest – Encrypts data stored on devices. Safeguards sensitive information even if a device is stolen or lost. Holding information behind login credentials can stall the exporting of sensitive company data. This control applies to all hardware approved to host company operations.
- AU-12 – Audit Record Generation – Audit Record Generation Ensures logging of security events. Audit records provide visibility into security incidents–without a good picture of what is occurring, security issues cannot be addressed properly. Any suspicious login attempts can be investigated.
- AC-19 – Access Control for Mobile Devices – Applies security controls to remote endpoints. Ensures mobile devices meet security requirements before access.Utilizing your mobile device on company hardware is a privilege–to continue using mobile devices on company networks, they must meet minimum security requirements.
- SC-18 – Mobile Code – Controls execution of potentially risky mobile code. Prevents unauthorized or harmful scripts from running on workstations. Anything not explicitly permitted by administration or the information security team is not allowed–only special permission or operational changes can bring new code into the Flyer Tech operational environment.

LAN Domain

Encompasses the equipment that makes up the LAN. A LAN typically has network devices that connect to the local office, building, or area in general (Local Area Network).

Applicable Policies & Standards

Policy 1 – Acceptable Encryption – This policy ensures that data transmitted over the LAN is encrypted to protect against unauthorized access;

Policy 4 – Bluetooth Baseline Requirements Policy – This policy sets the requirements for Bluetooth devices connected to the LAN, ensuring that they meet minimum security standards;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents on the LAN;

Policy 12 – Server Security Policy – This policy defines how information is logged on the LAN, including system events and user activities;

Policy 8 – Information Logging Policy – This policy governs the security of servers on the LAN, including access controls and vulnerability management;

Policy 14 – Technology Equipment Disposal Policy – This policy outlines the procedures for disposing of LAN equipment in a secure manner;

Policy 15 – Wireless Communication Policy – This policy governs the use of wireless communication on the LAN, including Wi-Fi and other wireless technologies;

Standard 1 – Data Protection Standard – The LAN must be configured to protect sensitive data, including encrypting data at rest and in transit;

Standard 3 – Bluetooth Baseline Requirement Standard – The LAN must be configured to meet the organization's Bluetooth security requirements;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – LAN administrators must report any security incidents to the incident response team;

Standard 6 – Information Logging Standard – The LAN must be configured to log security-related events, such as login attempts and access to sensitive data;

Standard 9 – Server Security Standard – LAN servers must be configured to meet the organization's server security requirements, including patch management and access controls;

Standard 10 – Wireless Communication Standard – The LAN must be configured to meet the organization's wireless communication security requirements, including encryption and authentication.

Controls for LAN Domain

- SC-7 – Boundary Protection – Controls traffic flow at network boundaries. Prevents unauthorized data flow and access into and out of workstations. Information meant for a specific department should not be passed to another unless permitted–the Flyer Tech LAN network would need control avenues that information flows through.
- AC-4 – Information Flow Enforcement – Enforces rules on how information moves between systems. Prevents unauthorized or unfiltered data exchanges within the LAN. This control would work off of SC-7, enforcing proper usage of the Flyer Tech LAN for data exchanges.
- CM-8 – System Component Instrument – Maintains an up-to-date inventory of devices and components. Enhanced visibility and control over network assets–proper control of Flyer Tech instruments would make the chances of breach from a lost or stolen device minimum. Devices signed out operating on the LAN network need to have a method of tracking.

- SI-4 – System Monitoring – Monitors system and network activity for security events. Detects anomalies and enables quick incident response–proper monitoring systems that alert and record instances on the LAN assist for rectifying the incident. LAN network activity, while local, can still be taken advantage of or mishandled from within.
- SC-32 – System Partitioning – Segregates functions into isolated zones. Limits the impact of breaches by containing them within defined boundaries–boundaries are beneficial for effectively responding and troubleshooting issues without the chance of the entire Flyer Tech network going down. Hosting multiple LAN servers allows for redundancy if something were to go down.
- PE-3 – Physical Access Control – Restricts physical access to network resources. Prevents unauthorized individuals from tampering with LAN infrastructure–no unauthorized personnel should be able to access the LAN network. Company networks are restricted from the public, the network monitoring systems in the previous controls will assist in controlling this aspect.
- SC-36 – Distribute Processing and Storage – Manages how processing and data are distributed. Enhances system resilience and performance through decentralization–multiple avenues can reduce bottle-necking on the LAN. In addition, data flowing through different paths can make things harder to trace from the outside–threat actors would have a difficult time parsing data.
- SC-34 – Non-Modifiable Executable Programs – Prevents execution of unauthorized code. Reduces risk of malware and unauthorized application use. With the use of redundancy restricting the spread of malicious software,

restrictions on the Flyer Tech network and devices will restrict the chances of this malware executing and potentially spreading throughout the LAN.

- MP-7 – Media Use – Controls use of removable media. Limits data exfiltration and malware introduction via USBs, CDs, etc–foreign storage devices are restricted under all cases without approval from the administration and information security team. The chances of malware being introduced and spread is low but not negligible, no personnel may make an attempt.
- AC-17 – Remote Access – Governs how users connect to the LAN remotely. Ensures secure, controlled access to internal resources. Accessing company hardware via remote access is allowed–means of connection must be pre-approved with proper security controls prior to the remote access being permitted. The information security team are the only individuals to grant permission for remote access.

LAN to WAN Domain

This is the bridge between LAN and a WAN(Wide Area Network). Where LAN is efficient within an area, going further than the printer calls for a WAN. The Internet is a WAN, and like many WANs, the internet is public and considered insecure.

Applicable Policies & Standards

Policy 1 – Acceptable Encryption – This policy ensures that data transmitted between the LAN and WAN is encrypted to protect against unauthorized access;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents between the LAN and WAN;

Policy 11 – Remote Access Policy – This policy governs remote access to the LAN from the WAN, including rules for authentication and authorization;

Policy 15 – Wireless Communication Policy – This policy governs the use of wireless communication between the LAN and WAN, including Wi-Fi and other wireless technologies;

Standard 1 – Data Protection Standard – Data transmitted between the LAN and WAN must be protected, including encrypting data in transit;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – LAN to WAN administrators must report any security incidents to the incident response team.

Controls for LAN to WAN Domain

- SC-7 – Boundary Protection – Controls traffic flow at network boundaries. Prevents unauthorized data flow and access into and out of workstations. Controlling the flow of the network when moving from the local network to the broad internet is crucial for company operations–once you enter the proximity of the internet, security must be taken to the extreme. Strict controls are to be placed on what information can exit the Flyer Tech LAN and enter the Flyer Tech WAN.
- SC-12 – Cryptographic Key Establishment and Management – Applies encryption to protect user credentials and communications. Secures sensitive data, especially in login sessions and email–proprietary company data should not be easily accessible from outside the Flyer Tech network. Encrypted information at a user level through proper credentials or virtual private networks is for personnel and company protection.

- SC-23 – Session Authenticity – Validates session identities. Prevents session hijacking and impersonation–interactions between LAN and WAN are to have identities validated at every corner. MFA is to be used.
- AC-4 – Information Flow Enforcement – Enforces rules on how information moves between systems. Prevents unauthorized or unfiltered data exchanges within the LAN. Information should not be getting passed from LAN to LAN, the integrity of local networks is how we keep the separate department operations from getting muddied with each other's business.
- SI-4 – System Monitoring – Monitors system and network activity for security events. Detects anomalies and enables quick incident response–proper monitoring systems that alert and record instances from the LAN to WAN assist with rectifying the incident. LAN to WAN network activity must be taken seriously, it can easily be breached from the outside or mishandled when negligence is present.
- AU-2 – Event Logging – Logs security-relevant events. Supports auditing, troubleshooting, and compliance. Tracking every login or logoff can help pinpoint who was on during the instance of a breach–whether automated or manual, efforts must be made to keep records of the relevant events. Security tests and any user introduction or removal would qualify as security-relevant.
- CM-3 – Configuration Change Control – Manages changes to system configurations. Prevents unauthorized or risky changes to network devices–any and all configuration changes must be approved by both the Flyer Tech administration and the network security team. Control over this element will

minimize chances of weak spots in company security–no efforts outside of pre-approved changes are to be made by any member of staff.

- IR-4 – Incident Handling – Defines incident response procedures. Enables effective and coordinated reaction to cyber threats. Without an outlined method to address incidents, the response effort to breaches would be ineffective. Proper incident documentation also goes a long way when securing the Flyer Tech network inside and out.
- SC-44 – Detonation Chambers – Sandboxes suspicious files. Detects malicious behavior in a safe, isolated environment. Having an environment to interact with and test malicious software or behaviours can be beneficial to bettering incident responses and knowing what to rule out or look for specifically. Isolated environments act as a lab to learn how to remediate the effects of such malicious entities.
- SC-8 – Transmission Confidentiality and Integrity – Encrypts data in transit. Protects sensitive information from eavesdropping and tampering. Encrypting data over entering or exiting the LAN from the WAN or vise-versa will be the only way to effectively keep the bulk of Flyer Tech data online secure. Without the encryption of company data, the people of the internet could take advantage of the low security and affect business operations.

WAN Domain

The WAN domain is the way in which we connect to the internet. With being on the internet, keeping communications private and secure is a priority.

Applicable Policies & Standards

Policy 1 – Acceptable Encryption – This policy ensures that data transmitted over the WAN is encrypted to protect against unauthorized access;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents on the WAN;

Policy 7 – Email Policy – This policy governs the use of email over the WAN, including rules for sending and receiving emails;

Policy 11 – Remote Access Policy – This policy governs remote access to the WAN, including rules for authentication and authorization;

Standard 1 – Data Protection Standard – The WAN must be configured to protect sensitive data, including encrypting data at rest and in transit;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – WAN administrators must report any security incidents to the incident response team;

Standard 5 – Email Communication & Usage Standard – WAN users must adhere to the organization's email communication and usage policy;

Standard 8 – Remote Access Standard – WAN users must adhere to the organization's remote access policy, which outlines requirements for remote access to the organization's network.

Controls for WAN Domain

- SC-20 – Secure NAME/ADDRESS Resolution Service (Authoritative Source) – Ensures DNS data integrity and authenticity. Prevents redirection to malicious domains. Introducing the proper procedures hardening to internet data transfers will greatly benefit the security posture and confidence of Flyer Tech–extra

caution must be put in place to prevent the breach of what should be secure servers.

- SC-12 – Cryptographic Key Establishment and Management – Applies encryption to protect user credentials and communications. Secures sensitive data, especially in login sessions and email–proprietary company data should not be easily accessible from outside the Flyer Tech network. Encrypted information at a user level through proper credentials or virtual private networks is for personnel and company protection.
- CA-3 – Information Exchange – Controls external data sharing. Ensures data exchanged with third parties is protected and compliant. A secure tunnel is important to doing business outside of the Flyer Tech network–who our data is shared with and how it is shared is imperative for company communications.
- AC-4 – Information Flow Enforcement – Enforces rules on how information moves between systems. Prevents unauthorized or unfiltered data exchanges within the WAN. Information should not be getting passed throughout the WAN, the integrity of Flyer Tech networks is how we keep company information secure.
- SI-4 – System Monitoring – Monitors system and network activity for security events. Detects anomalies and enables quick incident response–proper monitoring systems that alert and record instances through the WAN assist with rectifying the incident. WAN network activity must be taken extremely seriously, it can easily be breached from the outside or mishandled when negligence is present.

- IA-3 – Device Identification and Authentication – Verifies device identities before granting access. Prevents rogue devices from joining the WAN. Unknown or rogue devices joining the WAN could cause issues for the continued operations of Flyer Tech–if a backdoor is created within the system it would be difficult to prevent data leaks to the WAN.
- SC-11 – Trusted Path – Establishes secure communication channels. Ensures users are not tricked by spoofed interfaces. In addition to more secure channels, means of authentication or verification would prevent forces external from Flyer Tech networks from gaining access or communicating with personnel on the network.
- SC-31 – Covert Channel Analysis – Analyzes systems for hidden data leakage paths. Prevents subtle data exfiltration techniques–backdoors would be easier to detect. Backdoors are a big issue when it comes to securing a large organization's data, Flyer Tech must take into account all that we don’t see in order to build a more secure WAN.
- PL-8 – Security and Privacy Architectures – Integrates privacy and security into system design. Ensures WAN protocols and systems consider risk from the ground up–knowing how Flyer Tech systems are going to be interacted with and adjusting based on the needs of the company. Proper design and security structural integrity could make for an ironclad system.
- SA-9 – External System Services – Manages security of third-party services. Reduces risk from using cloud or outsourced infrastructure. Interacting with systems outside of the Flyer Tech WAN becomes an issue when we do not have

control over their security systems of how the chosen company data is stored. Third-party services must match Flyer Tech security standards in order to be appropriately utilized.

Remote Access Domain

This can be described as an enhanced user domain. The difference between this and the user domain is that you are accessing the private and secure company network from an unsecure public network. All the issues from the user domain apply plus remote authentication and network connectivity issues.

Applicable Policies & Standards

Policy 1 – Acceptable Encryption – This policy ensures that data transmitted during remote access is encrypted to protect against unauthorized access;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents during remote access;

Policy 9 – Password Construction Guidelines – This policy sets the rules for creating strong passwords for remote access;

Policy 10 – Password Protection Policy – This policy governs the protection of passwords used for remote access;

Policy 11 – Remote Access Policy – This policy governs remote access to the network, including rules for authentication and authorization;

Policy 15 – Wireless Communication Policy – This policy governs the use of wireless communication during remote access, including Wi-Fi and other wireless technologies;

Standard 1 – Data Protection Standard – Remote access users must protect sensitive data, including encrypting data in transit;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – Remote access users must report any security incidents to the incident response team;

Standard 7 – Password Construction Standard – Remote access users must create strong, unique passwords that meet the organization's password complexity requirements;

Standard 8 – Remote Access Standard – Remote access users must adhere to the organization's remote access policy;

Standard 10 – Wireless Communication Standard – Remote access users must adhere to the organization's wireless communication security requirements.

Controls for Remote Access Domain

- AC-17 – Remote Access – Governs how users connect to the LAN remotely. Ensures secure, controlled access to internal resources. Privilege to remote connections comes with risks to the entire Flyer Tech network, having proper configurations protects the safety of the company and employees alike.
- IA-2 – Identification and Authentication – Enforces strong user verification processes. Verifies user identities before granting access, preventing impersonation. Proper avenues of authentication are crucial, especially in the remote access domain where a simple mistake could allow for a detrimental security breach.
- SC-12 – Cryptographic Key Establishment and Management – Applies encryption to protect user credentials and communications. Secures sensitive

data, especially in login sessions and email–proprietary company data should not be easily accessible from outside the Flyer Tech network. Encrypted information at a user level through proper credentials or virtual private networks is for personnel and company protection.

- SC-7 – Boundary Protection – Controls traffic flow at network boundaries. Prevents unauthorized data flow and access into and out of workstations. The network traffic flowing from one device to the Flyer Tech network must have proper boundaries while devices outside of the permitted authenticated operations of the company attempting to access it must be restricted and disallowed access.
- AC-19 – Access Control for Mobile Devices – Applies security controls to remote endpoints. Ensures mobile devices meet security requirements before access. Any mobile devices not meeting the minimum requirements outlined by the Flyer Tech security team will be disallowed on the network until the appropriate security configurations are in place.
- SI-4 – System Monitoring – Monitors system and network activity for security events. Detects anomalies and enables quick incident response–proper monitoring systems that alert and record instances of suspicious activity emanating from remote access points in order to assist in rectifying the incident. Remote access activity must be watched closely, the data flow from a remote device could easily be hijacked or breached without proper failsafes..
- SC-18 – Mobile Code – Controls execution of potentially risky mobile code. Prevents unauthorized or harmful scripts from running on workstations. Anything

not explicitly permitted by administration or the information security team is not allowed–only special permission or operational changes can bring new code into the Flyer Tech operational environment.

- MP-6 – Media Sanitization – Ensures secure erasure of data on media before reuse or disposal. Prevents data leakage from decommissioned or repurposed devices–should any decommissioned device retain remote access capabilities or are improperly disposed/dismantled, a great security risk arises on the Flyer Tech network. It is of the most importance that devices out of use are properly handled.
- SC-28 – Protection of Information at Rest – Encrypts data stored on devices. Safeguards sensitive information even if a device is stolen or lost. Holding information behind login credentials can stall the exporting of sensitive company data. This control applies to all hardware approved to host company operations.
- IR-6 – Incident Reporting – Requires users to report suspicious or malicious activity. Enables faster response to threats and educates users to be part of the detection process. Proper avenues to report and document security incidents is important for our security professionals to appropriately respond and secure us.

Systems/Applications Domain

Software handles the collecting, processing, and storing of company data. Business software is typically an application. This domain refers to all issues related to business software and applications.

Applicable Policies & Standards

Policy 1 – Acceptable Encryption – This policy ensures that data stored in systems and applications is encrypted to protect against unauthorized access;

Policy 3 – Artificial Intelligence Use Policy – This policy governs the use of artificial intelligence in systems and applications, including rules for AI development and deployment;

Policy 5 – Cyber Security Incident Documentation & Handling – This policy outlines the procedures for handling and documenting cyber security incidents in systems and applications;

Policy 8 – Information Logging Policy – This policy defines how information is logged in systems and applications, including system events and user activities;

Policy 9 – Password Construction Guidelines – This policy sets the rules for creating strong passwords for systems and applications;

Policy 10 – Password Protection Policy – This policy governs the protection of passwords used in systems and applications;

Policy 12 – Server Security Policy – This policy governs the security of servers in systems and applications, including access controls and vulnerability management;

Policy 13 – Software Installation Policy – This policy governs the installation of software in systems and applications, ensuring that only approved software is installed;

Policy 14 – Technology Equipment Disposal Policy – This policy outlines the procedures for disposing of technology equipment in systems and applications in a secure manner;

Standard 1 – Data Protection Standard – Systems and applications must be configured to protect sensitive data, including encrypting data at rest and in transit;

Standard 4 – Cyber Security Incident Documentation & Handling Standard – System and application administrators must report any security incidents to the incident response team;

Standard 6 – Information Logging Standard – Systems and applications must be configured to log security-related events, such as login attempts and access to sensitive data;

Standard 7 – Password Construction Standard – System and application users must create strong, unique passwords that meet the organization's password complexity requirements;

Standard 9 – Server Security Standard – Systems and applications must be configured to meet the organization's server security requirements, including patch management and access controls.

Controls for Systems/Applications Domain

- SI-2 – Flaw Remediation – Ensures timely patching of vulnerabilities. Reduces exposure to known exploits and enhances system resilience. Any discovered system exploits will have patches put in place–through routine penetration testing, security vulnerability scans, and incident reporting, our security measures will become more hardened, this also comes with attention placed on the ever maturing nature of our security posture.
- SC-28 – Protection of Information at Rest – Encrypts data stored on devices. Safeguards sensitive information even if a device is stolen or lost. Holding information behind login credentials can stall the exporting of sensitive company data. This control applies to all hardware approved to host company operations.

- AC-6 – Least Privilege – Restricts users to only the access they need. Minimizes damage from account compromise or misuse. Personnel at Flyer Tech with less responsibility requirements do not require higher clearance–human resources do not need the ability to access the same information as our information security team. Alternatively, someone in security does not need access to company financial records.
- AU-2 – Event Logging – Logs security-relevant events. Supports auditing, troubleshooting, and compliance. Tracking every login or logoff can help pinpoint who was on during the instance of a breach–whether automated or manual, efforts must be made to keep records of the relevant events. Security tests and any user introduction or removal would qualify as security-relevant.
- CM-6 – Configuration Settings – Enforces secure settings in application environments. Prevents misconfiguration-related vulnerabilities–if company applications are improperly configured, our systems could become more breach prone. Properly ensuring security settings are appropriately set protect Flyer Tech hardware and networks.
- SC-3 – Security Function Isolation – Segregates security functions from normal operations. Protects critical components from tampering–newly introduced software could attack critical components. Separating the functions of Flyer Tech security systems would prevent malware from making its own alterations.
- SC-22 – Architecture and Provisioning for Flyer Tech/Romeoville Resolution Service – Ensures secure handling of DNS queries. Prevents DNS-based attacks like spoofing or cache poisoning. Without provisions or controls surrounding this

area of the Flyer Tech architecture, attacks could siphon data causing large data leaks.

- IR-4 – Incident Handling – Defines incident response procedures. Enables effective and coordinated reaction to cyber threats. Without an outlined method to address incidents, the response effort to breaches would be ineffective. Proper incident documentation also goes a long way when securing the Flyer Tech network inside and out.
- IA-5 – Authenticator Management – Governs creation, distribution, and revocation of credentials. Strengthens the integrity and protection of passwords and tokens. Controlling how, who, and when credentials are made, given, and taken away build makes tracing a paper trail much easier. If a set of credentials slide through the cracks and a threat actor finds them, the documentation and protocols surrounding credentials will make it very simple to track down–breaches can be pinpointed.
- SC-18 – Mobile Code – Controls execution of potentially risky mobile code. Prevents unauthorized or harmful scripts from running on workstations. Anything not explicitly permitted by administration or the information security team is not allowed–only special permission or operational changes can bring new code into the Flyer Tech operational environment.

Part 4 – Conclusions and Outcomes of Overall Report

The purpose of this security policy is to provide a clear, actionable set of guidelines that protect the confidentiality, integrity, and availability of Flyer Tech systems, data, and resources. Reinforcing core cybersecurity practices assists in pacing with ever-evolving digital threats–the scale and complexity of attacks has only gotten worse in past years. The policies and standards outlined in this document are not designed solely not only to meet regulatory and industry compliance, but to nurture a more secure and sound culture of accountability and risk awareness throughout Flyer Tech.

Each participating member of our system including employees, contractors, and third-party partners has a duty to comprehend and comply with these policies–whether it involves better password creation methods, up-to-date security configurations for devices, proper incident documentation, or responsible use of the Flyer Tech network, devices, and programs, consistent adherence is an integral piece of maintaining the security posture and integrity or Flyer Tech operations. Ignorance of policy is no excuse–security awareness training and readily available documentation are established to ensure this company and its personnel are resilient to any threats we may face.

Non-compliance of any form may be met with disciplinary action, this action including loss of access privileges, formal reprimand, or termination of employment. In serious cases, legal consequences may apply. Enforcement of these policies is

necessary not only for individual accountability, but for the collective confidence in the security of our organization.

Security is not the responsibility of a single department, but a reflection of the shared commitment we all adhere to. By communicating, having keen eyes, and adhering to the guidelines, we nurture a structurally sound and better equipped, secure environment where innovation and growth can flourish. With an ever-changing climate of threats, this policy will be reviewed regularly and updated to ensure it reflects the current best security practices and uplifts organizational needs.

Flyer Tech appreciates and thanks all staff for their dedication to upholding our security posture and protecting what matters most.

References

1. Easttom C., Johnson R. (2022). Security Policies and Implementation Issues
2. National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-53r5
3. SANS Institute. (n.d.). *Security policy templates*. Retrieved May 12, 2025, from https://www.sans.org/information-security-policy/